

Vertrag über die Auftragsverarbeitung

gemäß Art. 28 der Datenschutz-Grundverordnung (DSGVO)

Dieser Vertrag über die Auftragsverarbeitung („Vertrag“ oder „AVV“) konkretisiert die datenschutzrechtlichen Pflichten der Vertragsparteien, die sich aus der Verarbeitung personenbezogener Daten im Auftrag im Rahmen des zwischen den Parteien bestehenden Hauptvertrags über die Nutzung der SaaS-Plattform „Contract AI“ (der „Hauptvertrag“) ergeben. Er gilt für alle Tätigkeiten, bei denen der Auftragsverarbeiter personenbezogene Daten für den Verantwortlichen im Sinne des Art. 4 Nr. 8 DSGVO verarbeitet.

Verantwortlicher (Auftraggeber) – im Folgenden „Verantwortlicher“

Verantwortlicher im Sinne dieses Vertrags ist der jeweilige Auftraggeber (Kunde), der den Hauptvertrag über die Nutzung der Plattform Contract AI abschließt bzw. das betreffende Nutzerkonto betreibt und in diesem Rahmen personenbezogene Daten über die Plattform verarbeiten lässt. Dieser Vertrag gilt für jeden solchen Auftraggeber, ohne dass es einer gesonderten namentlichen Eintragung bedarf; die Identität des Verantwortlichen ergibt sich aus den Stammdaten des jeweiligen Nutzerkontos sowie dem zugrunde liegenden Hauptvertrag.

– und –

Auftragsverarbeiter – im Folgenden „Auftragsverarbeiter“

Anbieter	Contract AI – Inhaber Noah Liebold (Einzelunternehmen)
Anschrift	Richard-Oberle-Weg 27, 76648 Durmersheim, Deutschland
USt-IdNr.	DE361461136
Kontakt	info@contract-ai.de · Tel. 0176 5554 9923

Der Verantwortliche und der Auftragsverarbeiter werden nachfolgend einzeln auch „Partei“ und gemeinsam „Parteien“ genannt.

§ 1 Gegenstand, Art und Zweck der Verarbeitung

(1) Gegenstand des Auftrags ist die Verarbeitung personenbezogener Daten durch den Auftragsverarbeiter im Auftrag und nach Weisung des Verantwortlichen im Rahmen der Bereitstellung der Plattform Contract AI (KI-gestützte Analyse, Verwaltung, Optimierung, Erstellung und Fristenüberwachung von Verträgen).

(2) Art und Zweck der Verarbeitung, die Art der personenbezogenen Daten sowie die Kategorien betroffener Personen ergeben sich abschließend aus Anlage 1 zu diesem Vertrag.

(3) Die Verarbeitung findet ausschließlich innerhalb der Europäischen Union bzw. des Europäischen Wirtschaftsraums statt, soweit in Anlage 3 nicht ausdrücklich etwas anderes geregelt ist (Drittlandtransfer, vgl. § 9).

§ 2 Dauer des Auftrags

Die Laufzeit dieses Vertrags entspricht der Laufzeit des Hauptvertrags. Eine Kündigung des Hauptvertrags gilt zugleich als Kündigung dieses Vertrags. Eine isolierte Kündigung dieses Vertrags ist ausgeschlossen, solange der Hauptvertrag fortbesteht. Die Regelungen zur Löschung und Rückgabe (§ 10) bleiben über das Vertragsende hinaus wirksam.

§ 3 Weisungsrecht des Verantwortlichen

(1) Der Auftragsverarbeiter verarbeitet personenbezogene Daten ausschließlich im Rahmen der getroffenen Vereinbarungen und nach dokumentierten Weisungen des Verantwortlichen, es sei denn, er ist nach dem Recht der Union oder der Mitgliedstaaten, dem er unterliegt, zur Verarbeitung verpflichtet (Art. 28 Abs. 3 lit. a DSGVO). In einem solchen Fall teilt der Auftragsverarbeiter dem Verantwortlichen diese rechtlichen Anforderungen vor der Verarbeitung mit, sofern das betreffende Recht eine solche Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet.

(2) Weisungen werden grundsätzlich in Textform (z. B. per E-Mail an info@contract-ai.de) erteilt. Mündliche Weisungen sind unverzüglich in Textform zu bestätigen. Der Hauptvertrag und dieser AVV nebst Anlagen stellen die initiale, vollständige Weisung des Verantwortlichen dar.

(3) Der Auftragsverarbeiter informiert den Verantwortlichen unverzüglich, wenn er der Auffassung ist, dass eine Weisung gegen datenschutzrechtliche Vorschriften verstößt (Art. 28 Abs. 3 S. 3 DSGVO). Der Auftragsverarbeiter ist berechtigt, die Durchführung der betreffenden Weisung auszusetzen, bis sie durch den Verantwortlichen bestätigt oder geändert wird.

§ 4 Pflichten des Auftragsverarbeiters

Der Auftragsverarbeiter verpflichtet sich insbesondere zu Folgendem:

- a) die Verarbeitung ausschließlich gemäß § 3 (Weisungsbindung) durchzuführen; verarbeitet er Daten für andere Zwecke oder bestimmt er Mittel der Verarbeitung selbst, gilt er insoweit als Verantwortlicher (Art. 28 Abs. 10 DSGVO);
- b) zu gewährleisten, dass sich die zur Verarbeitung befugten Personen zur Vertraulichkeit verpflichtet haben oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen (Art. 28 Abs. 3 lit. b, Art. 29, Art. 32 Abs. 4 DSGVO);
- c) alle gemäß Art. 32 DSGVO erforderlichen technischen und organisatorischen Maßnahmen zu ergreifen und einzuhalten (im Einzelnen Anlage 2);
- d) die Bedingungen für die Inanspruchnahme weiterer Auftragsverarbeiter (Unterauftragnehmer) nach § 6 dieses Vertrags einzuhalten (Art. 28 Abs. 2 und 4 DSGVO);
- e) den Verantwortlichen nach Maßgabe von § 7 bei der Erfüllung der Rechte betroffener Personen (Art. 12–23 DSGVO) zu unterstützen;
- f) den Verantwortlichen bei der Einhaltung der in den Art. 32 bis 36 DSGVO genannten Pflichten zu unterstützen (Datensicherheit, Meldung von Verletzungen, Datenschutz-Folgenabschätzung, vorherige Konsultation), unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen;
- g) nach Wahl des Verantwortlichen sämtliche personenbezogenen Daten nach Abschluss der Erbringung der Verarbeitungsleistungen zu löschen oder zurückzugeben (§ 10);
- h) dem Verantwortlichen alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten aus Art. 28 DSGVO zur Verfügung zu stellen und Überprüfungen zu ermöglichen (§ 11);
- i) ein Verzeichnis aller Kategorien von im Auftrag durchgeführten Verarbeitungstätigkeiten gemäß Art. 30 Abs. 2 DSGVO zu führen.

Der Auftragsverarbeiter hat einen betrieblichen Datenschutzbeauftragten zu benennen, sofern eine gesetzliche Bestellopflicht nach Art. 37 DSGVO bzw. § 38 BDSG besteht. Kontakt für Datenschutzanfragen: info@contract-ai.de.

§ 5 Technische und organisatorische Maßnahmen (TOM)

(1) Der Auftragsverarbeiter trifft die in Anlage 2 beschriebenen technischen und organisatorischen Maßnahmen, um ein dem Risiko angemessenes Schutzniveau nach Art. 32 DSGVO sicherzustellen. Die Maßnahmen sind dem Verantwortlichen vor Beginn der Verarbeitung bekannt und werden von diesem als angemessen anerkannt.

(2) Die technischen und organisatorischen Maßnahmen unterliegen dem technischen Fortschritt. Dem Auftragsverarbeiter ist es gestattet, alternative angemessene Maßnahmen umzusetzen, sofern das Sicherheitsniveau der festgelegten Maßnahmen nicht unterschritten wird. Wesentliche Änderungen sind zu dokumentieren.

§ 6 Unterauftragsverhältnisse

(1) Der Verantwortliche erteilt dem Auftragsverarbeiter die allgemeine Genehmigung, weitere Auftragsverarbeiter (Unterauftragnehmer) hinzuzuziehen (Art. 28 Abs. 2 S. 1 DSGVO). Die zum Zeitpunkt des Vertragsschlusses eingesetzten Unterauftragnehmer sind in Anlage 3 aufgeführt und werden hiermit genehmigt.

(2) Beabsichtigt der Auftragsverarbeiter, einen weiteren Unterauftragnehmer hinzuzuziehen oder einen bestehenden zu ersetzen, informiert er den Verantwortlichen vorab in Textform. Der Verantwortliche kann einer solchen Änderung innerhalb von 14 Tagen aus wichtigem datenschutzrechtlichem Grund widersprechen (Art. 28 Abs. 2 S. 2 DSGVO). Erfolgt kein Widerspruch innerhalb der Frist, gilt die Änderung als genehmigt.

(3) Der Auftragsverarbeiter erlegt jedem Unterauftragnehmer durch Vertrag dieselben Datenschutzpflichten auf, wie sie in diesem Vertrag festgelegt sind (Art. 28 Abs. 4 DSGVO). Kommt der Unterauftragnehmer seinen Datenschutzpflichten nicht nach, haftet der Auftragsverarbeiter gegenüber dem Verantwortlichen für die Einhaltung der Pflichten des Unterauftragnehmers.

(4) Dienstleistungen, die der Auftragsverarbeiter als bloße Nebenleistung in Anspruch nimmt (z. B. Telekommunikations- oder Reinigungsleistungen), gelten nicht als Unterauftragsverhältnisse im Sinne dieses Vertrags.

§ 7 Unterstützung bei Betroffenenrechten

(1) Macht eine betroffene Person Rechte (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch – Art. 15–21 DSGVO) gegenüber dem Auftragsverarbeiter geltend, verweist dieser die betroffene Person an den Verantwortlichen, sofern eine Zuordnung zum Verantwortlichen möglich ist, und leitet das Ersuchen unverzüglich an den Verantwortlichen weiter.

(2) Der Auftragsverarbeiter unterstützt den Verantwortlichen im Rahmen seiner Möglichkeiten mit geeigneten technischen und organisatorischen Maßnahmen dabei, dessen Pflicht zur Beantwortung von Anträgen betroffener Personen nachzukommen (Art. 28 Abs. 3 lit. e DSGVO). Soweit die Mitwirkung über die im Hauptvertrag vereinbarten Leistungen hinausgeht, kann der Auftragsverarbeiter hierfür eine angemessene Vergütung verlangen.

§ 8 Meldung von Verletzungen des Schutzes personenbezogener Daten

(1) Der Auftragsverarbeiter meldet dem Verantwortlichen jede ihm bekannt gewordene Verletzung des Schutzes personenbezogener Daten, die die im Auftrag verarbeiteten Daten betrifft, unverzüglich (in der Regel innerhalb von 48 Stunden) nach Bekanntwerden (Art. 33 Abs. 2 DSGVO).

(2) Die Meldung an den Verantwortlichen enthält mindestens:

- eine Beschreibung der Art der Verletzung, soweit möglich mit Angabe der betroffenen Kategorien und der ungefähren Zahl der betroffenen Personen und Datensätze;
- eine Beschreibung der wahrscheinlichen Folgen der Verletzung;
- eine Beschreibung der ergriffenen oder vorgeschlagenen Maßnahmen zur Behebung der Verletzung und zur Abmilderung möglicher nachteiliger Auswirkungen;
- den Namen und die Kontaktdaten einer Anlaufstelle für weitere Informationen.

(3) Die Meldepflichten des Verantwortlichen gegenüber der Aufsichtsbehörde (Art. 33 DSGVO) und gegenüber betroffenen Personen (Art. 34 DSGVO) bleiben hiervon unberührt und obliegen allein dem Verantwortlichen.

§ 9 Verarbeitung in Drittländern

(1) Eine Verarbeitung personenbezogener Daten in einem Land außerhalb der EU/des EWR (Drittland) findet nur statt, soweit dies in Anlage 3 ausgewiesen ist und die besonderen Voraussetzungen der Art. 44 ff. DSGVO erfüllt sind.

(2) Für Übermittlungen in die USA stützt sich der Auftragsverarbeiter, soweit der jeweilige Empfänger unter dem EU-US Data Privacy Framework (DPF) zertifiziert ist, auf den Angemessenheits-beschluss der Europäischen Kommission vom 10. Juli 2023. Ergänzend bzw. für nicht unter dem DPF zertifizierte Empfänger werden die Standardvertragsklauseln der EU-Kommission (SCC, Durchführungsbeschluss (EU) 2021/914) nebst erforderlicher zusätzlicher Schutzmaßnahmen vereinbart.

§ 10 Löschung und Rückgabe nach Beendigung

(1) Nach Beendigung der Verarbeitungsleistungen löscht der Auftragsverarbeiter nach Wahl des Verantwortlichen sämtliche personenbezogenen Daten oder gibt sie zurück und löscht vorhandene Kopien, sofern nicht nach dem Recht der Union oder der Mitgliedstaaten eine Verpflichtung zur Speicherung der Daten besteht (Art. 28 Abs. 3 lit. g DSGVO).

(2) Der Verantwortliche kann seine Daten während der Vertragslaufzeit jederzeit selbst über die Funktionen der Plattform exportieren und löschen. Eine Löschung erfolgt spätestens 30 Tage nach Beendigung des Hauptvertrags, soweit keine gesetzlichen Aufbewahrungspflichten (z. B. handels- und steuerrechtliche Fristen) entgegenstehen. Für die Dauer einer gesetzlichen Aufbewahrungspflicht werden die Daten gesperrt.

(3) Die Dokumentation, die dem Nachweis der ordnungsgemäßen Verarbeitung dient, ist durch den Auftragsverarbeiter entsprechend den jeweiligen Aufbewahrungsfristen auch über das Vertragsende hinaus aufzubewahren.

§ 11 Nachweise und Kontrollrechte

(1) Der Auftragsverarbeiter stellt dem Verantwortlichen auf Anfrage alle erforderlichen Informationen zum Nachweis der Einhaltung der in Art. 28 DSGVO niedergelegten Pflichten zur Verfügung (Art. 28 Abs. 3 lit. h DSGVO).

(2) Der Verantwortliche ist berechtigt, sich von der Einhaltung der technischen und organisatorischen Maßnahmen sowie der vertraglichen Pflichten zu überzeugen. Der Nachweis kann erfolgen durch aktuelle Testate, Zertifizierungen oder Berichte einer unabhängigen Instanz (z. B. der eingesetzten Unterauftragnehmer) oder eine geeignete Selbstauskunft.

(3) Soweit dies im Einzelfall erforderlich ist, ermöglicht der Auftragsverarbeiter Überprüfungen — auch vor Ort — durch den Verantwortlichen oder einen von diesem beauftragten, zur Verschwiegenheit verpflichteten Prüfer. Vor-Ort-Prüfungen sind mit angemessener Vorankündigung (mind. 14 Tage), zu den üblichen Geschäftszeiten und ohne Störung des Betriebsablaufs durchzuführen. Der hierfür anfallende angemessene Aufwand kann dem Verantwortlichen in Rechnung gestellt werden.

§ 12 Haftung

(1) Für die Haftung der Parteien gilt Art. 82 DSGVO. Im Verhältnis der Parteien zueinander gelten ergänzend die Haftungsregelungen des Hauptvertrags, soweit diese nicht zwingenden gesetzlichen Vorschriften widersprechen.

(2) Der Verantwortliche ist für die Zulässigkeit der Verarbeitung sowie für die Wahrung der Rechte betroffener Personen allein verantwortlich (Art. 4 Nr. 7, Art. 24 DSGVO).

§ 13 Schlussbestimmungen

(1) Änderungen und Ergänzungen dieses Vertrags sowie seiner Anlagen bedürfen der Textform. Dies gilt auch für die Aufhebung dieses Textformerfordernisses.

(2) Bei Widersprüchen zwischen diesem Vertrag und Regelungen des Hauptvertrags gehen die Regelungen dieses Vertrags in datenschutzrechtlicher Hinsicht vor.

(3) Sollte eine Bestimmung dieses Vertrags unwirksam sein oder werden, so wird die Wirksamkeit der übrigen Bestimmungen hiervon nicht berührt. Die Parteien verpflichten sich, die unwirksame Bestimmung durch eine wirksame zu ersetzen, die dem wirtschaftlichen Zweck am nächsten kommt.

(4) Es gilt das Recht der Bundesrepublik Deutschland. Gerichtsstand ist, soweit zulässig, der Sitz des Auftragsverarbeiters.

Abschluss des Vertrags

Dieser Vertrag zur Auftragsverarbeitung wird vom Auftragsverarbeiter bereitgestellt und ist einschließlich der Anlagen 1 bis 3 Bestandteil des Hauptvertrags über die Nutzung der Plattform Contract AI.

Für den Verantwortlichen (Auftraggeber)

Der Verantwortliche erkennt die Bedingungen dieses Vertrags mit der Registrierung bzw. der Nutzung der Plattform Contract AI sowie mit Abschluss des Hauptvertrags an. Einer gesonderten Unterzeichnung durch den Verantwortlichen bedarf es nicht; auf Wunsch kann der Verantwortliche diesen Vertrag gegenzeichnen.

Für den Auftragsverarbeiter



Noah Liebold
Inhaber · Contract AI

Durmersheim, im Juli 2026

Anlage 1 — Gegenstand und Einzelheiten der Verarbeitung

1. Gegenstand und Zweck der Verarbeitung

Bereitstellung der SaaS-Plattform Contract AI zur KI-gestützten Analyse, Verwaltung, Optimierung, Erstellung und Fristenüberwachung von Verträgen sowie zugehöriger Benachrichtigungs- und Kalenderfunktionen für den Verantwortlichen.

2. Art der Verarbeitung

Erheben, Erfassen, Speichern, Auslesen, Verwenden (KI-gestützte Analyse/Extraktion), Strukturieren, Übermitteln an Unterauftragnehmer (vgl. Anlage 3), Löschen und sonstige Bereitstellung im Rahmen der Plattformfunktionen.

3. Art der personenbezogenen Daten

- Bestands-/Stammdaten: Name, E-Mail-Adresse des Nutzers/Kontos;
- Zugangsdaten: Passwort (gehasht mit bcrypt), Authentifizierungs-/Session-Daten;
- Inhaltsdaten: hochgeladene Vertragsdokumente (PDF) und die darin enthaltenen personenbezogenen Daten von Vertragspartnern des Verantwortlichen (z. B. Namen, Anschriften, Vertrags- und Zahlungskonditionen, Fristen);
- Metadaten zu Dokumenten: Dateiname, Datum, Dateigröße, Hash, Nutzer-ID;
- Nutzungs- und Analysedaten: Analysehistorie, Erinnerungen/Fristen, Protokolldaten;
- Abrechnungsdaten: Name, E-Mail, Abonnement- und Zahlungsdaten (Zahlungsabwicklung über Stripe).

4. Kategorien betroffener Personen

- Nutzer und Mitarbeiter des Verantwortlichen, die die Plattform verwenden;
- Vertragspartner, Kunden und sonstige Dritte des Verantwortlichen, deren personenbezogene Daten in den hochgeladenen Dokumenten enthalten sind.

5. Dauer der Verarbeitung

Für die Laufzeit des Hauptvertrags zzgl. der in § 10 geregelten Lösch-/Aufbewahrungsfristen.

Anlage 2 – Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

Der Auftragsverarbeiter setzt die folgenden technischen und organisatorischen Maßnahmen ein, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten. Soweit Maßnahmen durch eingesetzte Unterauftragnehmer (Anlage 3) erbracht werden, beruhen sie auf deren zertifizierten Sicherheitsstandards (z. B. ISO 27001, SOC 2).

Schutzziel	Maßnahmen
Vertraulichkeit – Zutrittskontrolle	Betrieb in zertifizierten Rechenzentren der Unterauftragnehmer innerhalb der EU/des EWR mit physischer Zugangssicherung; keine eigenen On-Premise-Server.
Vertraulichkeit – Zugangskontrolle	Individuelle Benutzerkonten, Authentifizierung über JWT-Token, Passwörter ausschließlich gehasht gespeichert (bcrypt); E-Mail-Verifizierung für Neukonten.
Vertraulichkeit – Zugriffskontrolle	Rollen-/rechtebasierte Zugriffstrennung; mandantengetrennte Datenhaltung pro Nutzerkonto; Beschränkung administrativer Zugriffe auf das erforderliche Maß (need-to-know).
Integrität – Weitergabe-/Übertragungskontrolle	Durchgängige Transportverschlüsselung (TLS/SSL/HTTPS) für sämtliche Datenübertragungen, einschließlich der Übermittlung an die KI-Verarbeitung.
Integrität – Eingabekontrolle	Protokollierung (Logging) und Monitoring sicherheitsrelevanter Ereignisse zur Nachvollziehbarkeit von Eingabe, Änderung und Löschung.
Verfügbarkeit und Belastbarkeit	Regelmäßige Backups; Server-Hardening und Zugriffsbeschränkungen; Monitoring der Systemverfügbarkeit; Redundanz auf Ebene der Cloud-Infrastruktur.
Datentrennung	Logische Trennung der Daten nach Mandant/Nutzerkonto; Trennung von Produktiv- und Testumgebungen.
Datenminimierung / Speicherbegrenzung	Übermittlung an die KI-Verarbeitung nur im erforderlichen Umfang; keine Nutzung der Inhalte zu Trainingszwecken durch den KI-Dienstleister; Löschung bei OpenAI nach max. 30 Tagen.
Verfahren zur Überprüfung und Bewertung	Regelmäßige Überprüfung und Aktualisierung der Maßnahmen; Sicherheits-Updates; Auswahl von Unterauftragnehmern mit anerkannten Zertifizierungen.

Anlage 3 — Genehmigte Unterauftragnehmer

Der Verantwortliche genehmigt mit Abschluss dieses Vertrags den Einsatz der folgenden Unterauftragnehmer. Alle Anbieter mit Sitz bzw. Verarbeitung in den USA sind entweder unter dem EU-US Data Privacy Framework zertifiziert und/oder es bestehen EU-Standardvertragsklauseln (SCC) gemäß § 9 dieses Vertrags.

Unterauftragnehmer	Leistung	Ort der Verarbeitung	Transfergrundlage
Amazon Web Services (AWS S3)	Speicherung hochgeladener Vertragsdokumente (Objektspeicher)	EU/EWR (AWS)	EU/EWR; ergänzend DPF / SCC
OpenAI, L.L.C.	KI-gestützte Vertragsanalyse und -verarbeitung (kein Training, Löschung max. 30 Tage)	USA	EU-US Data Privacy Framework + SCC
Anthropic, PBC	KI-gestützte Vertragserstellung und Formular-Vorbereitung (kein Training der Modelle)	USA	EU-Standardvertragsklauseln (SCC)
Stripe Payments Europe, Ltd.	Zahlungs- und Abonnementabwicklung	EU — Dublin, Irland	EU/EWR
Vercel Inc.	Hosting/Auslieferung der Web-Anwendung (Frontend)	USA	EU-US Data Privacy Framework
Render Services, Inc.	Hosting der Backend-/API-Anwendung	EU — Frankfurt	EU/EWR
MongoDB, Inc. (MongoDB Atlas)	Datenbank (Konto-, Vertrags- und Metadaten)	EU — Frankfurt (eu-central-1)	EU/EWR

Stand dieser Liste: Juni 2026. Änderungen werden dem Verantwortlichen gemäß § 6 Abs. 2 dieses Vertrags mitgeteilt.